

Cybersecurity Risk Assessment Methodology

Version: 4.0

Effective Date: January 2026

Classification: CONFIDENTIAL -- Internal Use Only

Owner: Advisory & Consulting Practice

Approved By: Managing Director, Advisory Services

This document is the proprietary and confidential property of Meridian & Associates LLP. It is intended solely for internal use and for authorized client engagements. Unauthorized reproduction, distribution, or disclosure of this material is strictly prohibited. All frameworks, methodologies, and tools described herein are protected intellectual property.

1 Engagement Overview

Meridian's Cybersecurity Risk Assessment provides organizations with a comprehensive, independent evaluation of their security posture across people, processes, and technology. Our assessment methodology is aligned with the NIST Cybersecurity Framework (CSF) 2.0 and incorporates elements from ISO 27001, CIS Controls v8, and MITRE ATT&CK. The engagement is designed to provide actionable insights, not just findings -- every identified risk is accompanied by a prioritized remediation recommendation with estimated effort and cost.

Typical engagement duration is 6-8 weeks for a mid-sized organization (1,000-10,000 employees), scalable to 10-12 weeks for large enterprises with complex environments. The assessment team consists of 3-5 senior security consultants with CISSP, CISM, OSCP, and/or GIAC certifications.

2 Threat Landscape Analysis

The assessment begins with a threat landscape analysis that identifies the most relevant threat actors, attack vectors, and tactics for the client's industry and operating environment. Meridian maintains a proprietary Threat Intelligence Database aggregating data from open-source intelligence (OSINT), commercial threat feeds (Recorded Future, Mandiant), industry ISACs, and our own incident response casework.

- Nation-state actors: Advanced persistent threats (APTs) targeting intellectual property, critical infrastructure, and sensitive government data. Relevant TTPs mapped to MITRE ATT&CK groups.
- Organized crime: Ransomware-as-a-Service (RaaS) operations, business email compromise (BEC), credential harvesting, and financial fraud. Analysis of sector-specific targeting patterns.
- Insider threats: Malicious insiders, negligent employees, and compromised credentials. Assessment of the client's insider threat program maturity.
- Supply chain threats: Third-party software compromises (e.g., SolarWinds-style attacks), managed service provider compromises, and open-source dependency vulnerabilities.

3 NIST CSF Alignment Assessment

The core of Meridian's assessment evaluates the client's security capabilities against the six functions of the NIST Cybersecurity Framework 2.0: Govern, Identify, Protect, Detect, Respond, and Recover. Each function is broken down into categories and subcategories, and the client's maturity is assessed on a five-tier scale.

- Govern: Organizational context, risk management strategy, policies, oversight, supply chain risk.
- Identify: Asset management, risk assessment, improvement planning. Comprehensive inventory of hardware assets, software assets, data assets, and cloud resources.
- Protect: Identity management and access control, awareness and training, data security, platform security, technology infrastructure resilience.
- Detect: Continuous monitoring, adverse event analysis. Evaluation of SIEM deployment, log coverage, detection rules, and mean time to detect (MTTD) metrics.
- Respond: Incident management, incident analysis, incident response reporting and communication, incident mitigation. Review of incident response plans and tabletop exercise history.
- Recover: Incident recovery plan execution, incident recovery communication. Assessment of backup and disaster recovery capabilities, RTOs, and RPOs.

4 Zero Trust Architecture Evaluation

Meridian evaluates the client's progress toward a Zero Trust architecture across the seven pillars defined in the CISA Zero Trust Maturity Model: User, Device, Network, Application Workload, Data, Visibility and Analytics, and Automation and Orchestration. For each pillar, we assess current-state maturity, identify gaps against the client's target maturity level, and recommend specific technology and process investments.

Key Zero Trust capabilities assessed include: multi-factor authentication (MFA) coverage and strength, conditional access policies, microsegmentation implementation, software-defined perimeter (SDP) adoption, least-privilege access enforcement, just-in-time (JIT) access provisioning, continuous device compliance validation, and data-centric security controls (classification, labeling, DLP, encryption).

5 Identity and Access Management Maturity

Identity is the new security perimeter. Meridian's IAM assessment covers the full identity lifecycle: provisioning, authentication, authorization, governance, and deprovisioning.

- Directory services: Active Directory domain health, Azure AD/Entra ID configuration, federation and SSO implementations, B2B and B2C identity scenarios.
- Privileged access management (PAM): Assessment of PAM tool deployment (CyberArk, BeyondTrust, Delinea), session recording, credential vaulting, just-in-time privilege elevation, and standing privilege inventory.
- Access governance: Access certification campaigns, segregation of duties (SoD) controls, role-based access control (RBAC) model effectiveness, orphaned account identification.
- Authentication strength: MFA adoption rates, phishing-resistant MFA (FIDO2, Windows Hello for Business), password policy effectiveness, and credential compromise monitoring.

6 Endpoint and Cloud Security

6.1 Endpoint Detection and Response (EDR)

The assessment evaluates the client's EDR deployment coverage, configuration, and operational effectiveness. Key metrics include agent deployment rate (target: >98% of managed endpoints), detection rule coverage against MITRE ATT&CK techniques, alert investigation rate and mean time to investigate, and automated response action configuration. Leading EDR platforms assessed include CrowdStrike Falcon, Microsoft Defender for Endpoint, SentinelOne, and Carbon Black.

6.2 Cloud Security Posture Management (CSPM)

For clients with cloud workloads, Meridian assesses the cloud security posture using native and third-party tools (Microsoft Defender for Cloud, AWS Security Hub, Wiz, Orca, Prisma Cloud). The assessment covers IAM policy analysis, network exposure (public-facing resources, overly permissive security groups), encryption at rest and in transit, logging and monitoring coverage, and compliance against CIS Benchmarks for the relevant cloud platforms.

7 Vulnerability Management

Meridian assesses the maturity and effectiveness of the client's vulnerability management program across the full lifecycle: asset discovery, vulnerability scanning, risk prioritization, remediation tracking, and exception management.

- Scanning coverage: Percentage of assets scanned, scanning frequency (target: weekly for internet-facing, monthly for internal), authenticated vs. unauthenticated scans.
- Risk prioritization: Use of CVSS scores, CISA Known Exploited Vulnerabilities (KEV) catalog, and asset criticality for risk-based prioritization. Shift from severity-based to risk-based approach.
- Remediation SLAs: Critical vulnerabilities (CVSS 9.0+) remediated within 48 hours for internet-facing assets, 7 days for internal. High vulnerabilities (CVSS 7.0-8.9) within 14 days.
- Patching effectiveness: Percentage of vulnerabilities remediated within SLA, mean time to remediate, and reintroduction rate.

8 Incident Response Assessment

Meridian reviews the client's incident response program including the incident response plan (IRP), team structure and roles, communication protocols, forensic capabilities, and regulatory notification procedures. We evaluate the IRP against NIST SP 800-61r3 guidelines and assess the team's preparedness through a facilitated tabletop exercise simulating a realistic attack scenario (typically ransomware or business email compromise).

Key assessment areas include: incident classification and severity definitions, escalation procedures and decision trees, forensic evidence preservation procedures, legal counsel engagement triggers, regulatory notification timelines (GDPR 72-hour requirement, SEC 4-day rule, state breach notification laws), crisis communication templates, and post-incident review processes.

9 Third-Party Risk Assessment

Third-party risk is one of the fastest-growing attack vectors. Meridian evaluates the client's third-party risk management (TPRM) program including vendor inventory completeness, risk tiering methodology, assessment questionnaires (SIG Lite, SIG Core, CAIQ), continuous monitoring tools (SecurityScorecard, BitSight, RiskRecon), contract security requirements, and fourth-party visibility. The assessment produces a risk-ranked vendor list with specific remediation recommendations for high-risk third parties.

10 Penetration Testing Approach

Meridian's penetration testing offering complements the risk assessment with hands-on validation of security controls. Our testing methodology follows the PTES (Penetration Testing Execution Standard) and includes the following engagement types.

- External network penetration testing: Perimeter assessment of internet-facing assets, DNS enumeration, service identification, vulnerability exploitation, and post-exploitation activities.
- Internal network penetration testing: Assumes an initial foothold (compromised workstation) and attempts lateral movement, privilege escalation, domain compromise, and sensitive data access.
- Web application testing: OWASP Top 10 assessment, authentication and session management testing, input validation, business logic flaws, and API security testing.
- Social engineering: Phishing campaigns (email and SMS), pretexting, physical security assessments (badge cloning, tailgating, dumpster diving). Results measured as click rate, credential submission rate, and report rate.
- Red team engagements: Objective-based, adversary simulation exercises with no predefined scope limitations. Designed to test the client's detection and response capabilities against realistic threat scenarios. Duration: 4-8 weeks.

11 Deliverables and Reporting

The cybersecurity risk assessment produces three primary deliverables, each tailored to a different audience and purpose.

11.1 Executive Briefing

A 15-20 page presentation for the Board, C-suite, and senior leadership. Includes overall security posture rating (A-F scale), benchmark comparison against industry peers, top 5 strategic risks with business impact quantification, recommended investment priorities, and a 12-month strategic roadmap. Delivered as a 60-minute in-person briefing with Q&A.

11.2 Risk Heat Map

A visual representation of all identified risks plotted on a likelihood-vs-impact matrix, color-coded by NIST CSF function. The heat map enables rapid identification of the highest-priority risks and serves as a communication tool for risk committee discussions. Interactive version available in Power BI with drill-down to individual findings.

11.3 Remediation Roadmap

A detailed, prioritized plan of remediation actions organized into three horizons: Quick Wins (0-3 months, low effort, high impact), Foundation (3-9 months, moderate effort, structural improvements), and Strategic (9-18 months, significant investment, transformational capabilities). Each action item includes description, NIST CSF alignment, estimated effort (person-days), estimated cost, responsible party, dependencies, and expected risk reduction.

12 CISO Advisory Services

For clients without a full-time CISO or those seeking supplemental strategic guidance, Meridian offers a virtual CISO (vCISO) service. The vCISO provides strategic security leadership on a fractional basis (typically 2-4 days per month), including security program oversight, board and executive reporting, vendor evaluation and selection, security budget planning, regulatory compliance guidance, and incident response leadership. The vCISO engagement is staffed by a Meridian Director or Managing Director with 15+ years of security leadership experience.

13 Engagement Approach

Cybersecurity risk assessments are scoped based on organizational size, complexity, and regulatory environment. The following outlines a typical engagement structure:

- Timeline: 6-8 weeks for mid-sized organizations (1,000-10,000 employees); 10-12 weeks for large enterprises; 4-6 weeks for focused assessments (single domain such as IAM or cloud security).
- Team Composition: 1 Engagement Partner (CISO-level experience), 1 Project Manager, 2-3 Senior Security Consultants (CISSP, CISM, OSCP), 1 Penetration Tester (OSCP, GPEN), 1 GRC Analyst.
- Key Deliverables: Executive Briefing (15-20 pages), Detailed Findings Report (50-100+ pages), Risk Heat Map (interactive Power BI), Remediation Roadmap (3-horizon plan), Tabletop Exercise Report, Optional: Penetration Test Report (separate deliverable).

14 Related Case Studies & Key Personnel

The following case study and key personnel are directly relevant to cybersecurity risk assessment engagements:

- Financial Services Digital Transformation Case Study -- \$285B global bank; comprehensive cybersecurity posture assessment integrated into core banking modernization; led by Sarah Chen, Lead Partner. Identified and remediated 47 critical security gaps pre-deployment.
- Alex Petrov, Managing Director -- Cybersecurity Practice Lead, CISSP and CISM certified with 20+ years of experience in financial services and critical infrastructure security. Former CISO at a Fortune 100 financial institution.
- Thomas Chen, Senior Manager -- IT Audit and GRC specialist with deep expertise in SOC reporting, NIST CSF assessments, and regulatory compliance (PCI-DSS, HIPAA, GLBA). Certified CISA and CRISC.

15 Related Meridian Methodologies

Cybersecurity assessments frequently connect to broader transformation and risk management initiatives across the firm. Related documents include:

- Cloud Migration Methodology and Playbook (v3.5) -- Cloud security assessments are a standard component of Meridian's cloud migration program, performed during the Cloud Readiness Assessment phase.
- Standard Project Lifecycle Framework (v4.2) -- Security assessments are embedded in the SPL Design phase for all transformation engagements.
- Data, Analytics & AI Strategy Guide (v1.0) -- Data governance and responsible AI frameworks complement cybersecurity risk management for AI-enabled enterprises.
- Enterprise ERP Implementation Strategy (v2.3) -- ERP security architecture reviews are conducted during the ERP Design phase using the cybersecurity assessment methodology.